

Como os dados se *propagam na internet*

Antes de falar de privacidade em ferramentas de IA, é preciso entender o terreno: o caminho de uma informação desde o seu dispositivo, quem consegue ver o quê no trajeto, onde ela fica guardada e por que, uma vez publicada, é tão difícil apagá-la.

Pegada digital

Trânsito e HTTPS

Cópias e retenção

Rastreamento

LGPD

Dados e IA

Sua *pegada digital*

Tudo o que você faz on-line deixa rastros. Parte deles você cria de propósito. A outra parte é gerada sem que você perceba, e costuma ser a maior.

PEGADA ATIVA

O que você publica e envia

- Posts, comentários, fotos e currículos
- Formulários de cadastro e compras
- E-mails, mensagens e arquivos compartilhados
- **Prompts e documentos enviados a assistentes de IA**

PEGADA PASSIVA

O que é coletado sobre você

- Endereço IP, localização aproximada e horários de acesso
- Cookies e identificadores de navegador e de dispositivo
- Páginas visitadas, cliques e tempo de leitura
- Metadados de arquivos, como a localização GPS de uma foto

Persistente

Os dados costumam durar muito mais do que o contexto em que foram criados.

Replicável

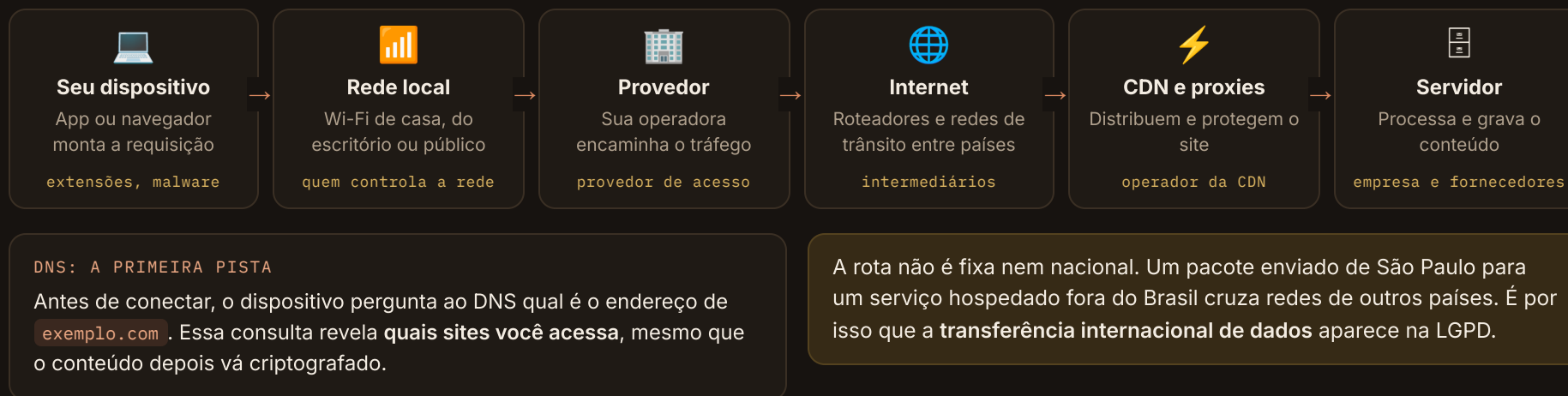
Copiar custa quase zero, e uma informação rapidamente existe em muitos lugares.

Combinável

Dados inofensivos isolados, quando cruzados, revelam muito sobre uma pessoa.

A viagem de uma *mensagem*

Ao enviar um formulário, um e-mail ou um prompt, os dados são quebrados em **pacotes** que passam por vários intermediários até o destino. Cada etapa é um ponto onde algo pode ser observado ou guardado.



O que o *HTTPS* protege, e o que não protege

O cadeado do navegador indica uma conexão **HTTPS** (TLS): o conteúdo trafega cifrado entre você e o servidor. Isso é essencial, mas não torna a comunicação invisível.

INFORMAÇÃO	VISÍVEL NA REDE?	VISÍVEL AO SERVIDOR?
Conteúdo: texto, senhas, arquivos	não	sim
Caminho da página (/conta/extrato)	não	sim
Domínio acessado (banco.com.br)	em geral, sim	sim
Seu endereço IP	sim	sim
Horário, duração e volume de dados	sim	sim

A LIÇÃO CENTRAL

O HTTPS protege o dado **em trânsito**. No destino, o servidor recebe tudo **em claro** para processar. A partir daí, o que acontece depende só de **quem opera o serviço** e das suas políticas.

Os **metadados** (quem, quando, de onde, quanto) contam muita coisa, mesmo sem o conteúdo: uma consulta às 3h da manhã num site de saúde já é uma informação sensível.

Sem o cadeado (HTTP puro), qualquer um no caminho, como a rede Wi-Fi pública, pode ler e até alterar o conteúdo.

Um dado, *muitas cópias*

Quando chega ao destino, a informação raramente fica num lugar só. Sistemas modernos multiplicam os dados para ganhar velocidade, resiliência e análise.

BANCO DE DADOS

A cópia principal, muitas vezes **replicada** em mais de uma região para não perder dados.

BACKUPS

Cópias de segurança guardadas por semanas ou anos. **Apagar da base não apaga do backup** na hora.

LOGS

Registros técnicos de acessos e erros que às vezes gravam, sem querer, trechos do conteúdo.

CACHES E CDNS

Cópias temporárias espalhadas pelo mundo para responder mais rápido.

ANALYTICS E FORNECEDORES

Ferramentas de terceiros (suporte, métricas, e-mail) que recebem parte dos dados.

FORA DO SISTEMA

Capturas de tela, e-mails encaminhados, planilhas exportadas: cópias que ninguém controla.

Por isso "apagar" é tão difícil: excluir um post remove a cópia visível, mas não necessariamente os backups, os caches, os arquivos de terceiros (como os arquivos da web) ou as capturas feitas por outras pessoas. A regra prática é **pensar antes de enviar**, porque depois o controle diminui.

Como você é *rastreado* entre sites

Além do que você envia, há um ecossistema inteiro dedicado a observar o que você faz e juntar essas observações num perfil.

TÉCNICA	COMO FUNCIONA
Cookies de 1ª parte	Guardados pelo próprio site: login, carrinho, preferências
Cookies de 3ª parte	De anunciantes embutidos em vários sites, que ligam suas visitas entre eles
Pixels e SDKs	Imagens invisíveis e bibliotecas em apps que avisam um terceiro quando você abre algo
Fingerprinting	Identifica o navegador pela combinação de fontes, tela, idioma e hardware, sem cookie
Login social	"Entrar com..." liga sua identidade real aos serviços que você usa

CORRETORES DE DADOS (DATA BROKERS)

Empresas que **compram, cruzam e revendem** perfis montados a partir de muitas fontes: navegação, compras, cadastros públicos e vazamentos.

METADADOS DE ARQUIVOS

Uma foto de celular pode trazer no EXIF a **localização GPS**, o modelo do aparelho e a hora. Um PDF ou DOCX pode trazer o **nome do autor** e o histórico de edição.

Antes de compartilhar um arquivo, remova os metadados. Muitos apps e sistemas operacionais têm a opção "remover localização".

Quando os dados *escapam*

Um vazamento raramente é um "hacker de filme". Na maioria das vezes, é uma combinação de erro humano, configuração errada e credencial reutilizada.

CONFIGURAÇÃO

Banco exposto

Base de dados ou storage na nuvem aberto por engano na internet.

CREDENCIAIS

Senha reutilizada

Senha vazada num site testada automaticamente em outros (*credential stuffing*).

ENGENHARIA SOCIAL

Phishing

Mensagem falsa que convence a pessoa a entregar acesso ou dados.

ERRO HUMANO

Envio indevido

Planilha com dados de clientes enviada ou colada no lugar errado.

EFEITO CASCATA

Dados vazados circulam em fóruns, são combinados com outros vazamentos e alimentam golpes cada vez mais convincentes, com seu nome, CPF e histórico de compras certos.

PROTEÇÕES QUE MAIS FUNCIONAM

- ✓ Senhas únicas com um gerenciador de senhas
- ✓ Autenticação em dois fatores (2FA)
- ✓ Desconfiar de urgência em mensagens
- ✓ Verificar se seu e-mail já apareceu em vazamentos públicos

A LGPD em cinco minutos

A Lei Geral de Proteção de Dados (Lei nº 13.709/2018) regula como pessoas e empresas tratam dados pessoais no Brasil. Ela vale para qualquer tratamento de dados de pessoas no país, inclusive feito por empresas estrangeiras.

CONCEITO	O QUE É
Dado pessoal	Informação que identifica ou pode identificar uma pessoa: nome, CPF, e-mail, IP, localização
Dado sensível	Saúde, origem racial ou étnica, religião, opinião política, filiação sindical, vida sexual, dados genéticos e biométricos
Titular	A pessoa a quem os dados se referem
Controlador	Quem decide o que fazer com os dados
Operador	Quem trata os dados em nome do controlador
ANPD	Autoridade Nacional de Proteção de Dados, que fiscaliza e aplica sanções

PRINCÍPIOS QUE GUIAM TUDO

- **Finalidade:** usar só para o propósito informado
- **Necessidade:** coletar o mínimo necessário
- **Transparência:** dizer ao titular o que é feito
- **Segurança:** proteger contra acesso indevido

DIREITOS DO TITULAR

Confirmar se há tratamento, acessar, corrigir, pedir a eliminação e a portabilidade dos dados e revogar o consentimento.

As sanções incluem advertência e multa de até **2% do faturamento** no Brasil, limitada a **R\$ 50 milhões por infração**, além da publicização da infração.

O *ciclo de vida* de um dado

Governança de dados é cuidar da informação em todas as etapas, não só na hora de guardar. Cada etapa tem uma pergunta que precisa ter resposta.

01

Coleta

Preciso mesmo deste dado? Com qual base legal?

02

Trânsito

Viaja cifrado? Por quais países e serviços passa?

03

Armazenamento

Onde fica, quem acessa e com quais permissões?

04

Processamento

Quais sistemas, pessoas e IAs usam o dado?

05

Compartilhamento

Quais fornecedores recebem? Há contrato?

06

Descarte

Quando é apagado, inclusive dos backups?

MINIMIZAÇÃO

O dado mais seguro é o que **nunca foi coletado**. Cada campo a mais num formulário é mais uma coisa para proteger, e mais uma para vazsar.

Guarde este ciclo: na aula 03 ele vira a base da **política de uso de IA** de uma empresa, com as mesmas seis perguntas aplicadas ao que se envia a um assistente.

O que muda quando o destino é uma *IA*

Um prompt é uma mensagem como outra qualquer: sai do seu dispositivo, viaja cifrado e é processado no servidor do provedor. A diferença está na **quantidade de contexto** que colamos sem pensar.

O QUE COSTUMA IR NUM PROMPT

- Trechos de contratos, e-mails e atas de reunião
- Planilhas com nomes, CPFs e valores de clientes
- Código-fonte, chaves de API e senhas esquecidas no meio
- Documentos internos e estratégicos

Shadow AI: quando funcionários usam contas pessoais de ferramentas de IA para trabalho, os dados da empresa saem do ambiente controlado, sem contrato, sem configuração e sem registro.

PERGUNTAS A FAZER SOBRE QUALQUER FERRAMENTA DE IA

- ✓ Os dados são usados para **treinar modelos**? Dá para desativar?
- ✓ Por quanto tempo as conversas ficam **retidas**?
- ✓ Quem na empresa fornecedora pode **acessar** o conteúdo?
- ✓ A conta é **pessoal ou corporativa**, e com quais garantias contratuais?
- ✓ Conectores e integrações dão acesso a **quais sistemas**?

As respostas mudam conforme o produto, o plano e as configurações. Na **aula 02** veremos como isso funciona no ecossistema Claude.

Boas práticas para o *dia a dia*

AO NAVEGAR

- ✓ Confira o HTTPS antes de digitar dados
- ✓ Evite Wi-Fi público para coisas sensíveis, ou use VPN confiável
- ✓ Revise permissões de apps e extensões
- ✓ Limpe ou bloqueie cookies de terceiros

AO COMPARTILHAR

- ✓ Remova metadados de fotos e documentos
- ✓ Compartilhe links com prazo e permissão mínima
- ✓ Pense se o dado precisa mesmo sair dali
- ✓ Anonimize: troque nomes e CPFs por exemplos

AO USAR IA

- ✓ Nunca cole senhas, tokens e chaves de API
- ✓ Use a conta **corporativa** para trabalho
- ✓ Revise as configurações de privacidade da ferramenta
- ✓ Envie o mínimo de contexto necessário

Teste rápido antes de enviar qualquer coisa: "Se este conteúdo aparecesse amanhã num vazamento, qual seria o estrago?" Se a resposta incomoda, reduza, anonimize ou não envie.

Teste *rápido*

1. Numa conexão HTTPS, o que o provedor de internet ainda consegue ver?

A) As senhas digitadas

B) O conteúdo da página

C) O domínio, o IP e o horário

D) Nada

C. O conteúdo vai cifrado, mas os metadados (domínio, IP, horário e volume) continuam visíveis na rede.

2. Você apagou um post. Por que ele ainda pode existir?

A) Não pode, apagou está apagado

B) Backups, caches, arquivos da web e capturas de terceiros

C) Só se o site for inseguro

D) Por causa do HTTPS

B. Os dados são replicados em muitos lugares, e excluir a cópia visível não remove as outras na hora.

3. Pela LGPD, qual destes é um dado pessoal sensível?

A) E-mail

B) Endereço IP

C) Diagnóstico de saúde

D) Nome completo

C. Dados de saúde estão entre os sensíveis. E-mail, IP e nome são pessoais, mas não sensíveis.

4. Um funcionário cola a planilha de clientes na conta pessoal de um chatbot. Como se chama esse risco?

A) Fingerprinting

B) Shadow AI

C) Credential stuffing

D) CDN

B. É o uso de ferramentas de IA fora do ambiente controlado pela empresa, sem contrato nem governança.

○ RECAPITULANDO

Pense antes de enviar: *dados viajam e ficam*

Cada informação que sai do seu dispositivo passa por vários intermediários, deixa metadados mesmo com HTTPS, é copiada para bancos, backups, logs e fornecedores e pode ser cruzada com outras. A LGPD dá direitos e deveres sobre esse ciclo, e as ferramentas de IA são só mais um destino, que pede o mesmo cuidado.

Pegada ativa e passiva

HTTPS ≠ invisível

Muitas cópias

LGPD

Shadow AI

Próxima aula → Privacidade no Claude

Referências: Lei nº 13.709/2018 (LGPD) e orientações da ANPD. Esta aula é introdutória e não substitui orientação jurídica. Consulte sempre as políticas atualizadas de cada serviço.